

Universidad Peruana
Cayetano Heredia

CARRERA DE INGENIERÍA INFORMÁTICA

Curso: SISTEMAS OPERATIVOS

Integrantes:

- Paloma Fernanda Velasquez (60921203)
- Daniel Fabricio Oliva Moscoso (73710164)
- Alex Jhosep Ccoyllo Sotelo (3476409)
- Jeral Alexander Cueva Zapata (74140816)
- Sofía Dayana Calva Becerra (60239714)
- Rosita Dayana Espinola Abanto (60825993)
- Marlon Steven Sarmiento Montalvo (75181595)

Grupo: 5
Profesor: Roberto Eduardo Burga Montañez
Semestre académico: 2026-2

1. Seguridad y Protección, Amenazas y Objetivos de Seguridad

1.1. Concepto de ciberespacio y sus componentes El ciberespacio es el entorno digital global y complejo donde interactúan redes, sistemas, dispositivos y usuarios. Se sostiene sobre cuatro componentes fundamentales:

- **Internet de las cosas (IoT):** Objetos físicos cotidianos (sensores, cámaras, vehículos, electrodomésticos) que están conectados a Internet, recopilando y transmitiendo datos constantemente.
- **Software:** Los programas, sistemas operativos, aplicaciones y códigos que permiten procesar la información y dar instrucciones al hardware.
- **TIC (Tecnologías de la Información y las Comunicaciones):** La infraestructura física y de red (servidores, cables de fibra óptica, enrutadores, antenas) que permite el almacenamiento y la transmisión de datos.
- **Personas:** Los individuos que interactúan en este entorno, desde usuarios comunes y administradores de sistemas, hasta los actores de amenazas (ciberdelincuentes).

1.2. Definición y crecimiento de la ciberdelincuencia

- **Definición:** Es cualquier actividad ilícita que utiliza computadoras, redes o dispositivos digitales como herramienta, objetivo principal o medio para cometer el delito (por ejemplo, robo de identidad, fraude financiero, distribución de *malware*).
- **Crecimiento:** Los incidentes cibernéticos han aumentado exponencialmente en los últimos años impulsados por la acelerada transformación digital, el aumento del trabajo remoto y la hiperconectividad. La ciberdelincuencia se ha profesionalizado, pasando de ataques individuales a complejas organizaciones criminales que ofrecen ataques como servicio (ej. *Ransomware as a Service*).

1.3. Objetivos y definición de ciberseguridad

- **Definición:** Es el conjunto de prácticas, tecnologías y procesos diseñados para proteger sistemas, redes, dispositivos, programas y datos contra ataques, daños o accesos no autorizados.
- **Objetivos:** El propósito central es salvaguardar los activos de información frente a las amenazas del ciberespacio. Esto se logra garantizando que la información no sea expuesta a terceros (Confidencialidad), que no sea alterada de forma ilegítima (Integridad) y que los sistemas y datos estén accesibles cuando se necesiten (Disponibilidad). Además, busca asegurar la continuidad operativa de las organizaciones y proteger la privacidad de las personas.

2. Intentos de Acceso no Autorizado

- Diferencia y relación entre la seguridad de la información y la ciberseguridad.
  SO-U12-Conceptos.pdf
    - Seguridad de la información : Es la preservación de la confidencialidad, integridad y disponibilidad de la información. Su objetivo es proteger la información independientemente de cómo se almacene o transmita, ya sea en documentos físicos o medios digitales.

    - Ciberseguridad: Consiste en proteger a las personas, la sociedad, las organizaciones y las naciones frente a los riesgos cibernéticos, manteniéndolos en un nivel tolerable. Se enfoca en los riesgos asociados al ciberespacio: redes, sistemas informáticos, servicios digitales y tecnologías conectadas.

- Pilares fundamentales: Confidencialidad, Integridad y Disponibilidad.
    - Confidencialidad : Impedir la divulgación no autorizada.
    - Integridad : Evitar alteraciones indebidas y mantener los datos exactos y completos.
    - Disponibilidad : Garantizar el acceso autorizado a la información.

- Definición y ejemplos de vulnerabilidades.
  SO-U12-Conceptos.pdf

Una vulnerabilidad es la debilidad de un activo o de un control que puede ser explotada por una o más amenazas. En otras palabras, es una falla o debilidad que puede comprometer la seguridad de la información. Se dividen en las siguiente categorías:

- Hardware: Mantenimiento insuficiente o instalación defectuosa de dispositivos de almacenamiento.
- Software: Pruebas de software insuficientes o interfaces complicadas.
- Red: Líneas de comunicación desprotegidas o puntos únicos de falla.
- Personal: Capacitación insuficiente en seguridad y trabajo no supervisado.
- Sitio: Red eléctrica inestable o instalaciones en zonas propensas a inundaciones.
- Organización: Falta de auditorías periódicas o procedimientos de supervisión ineficaces.

    -

- Tipos de agentes de amenaza, amenazas a los activos y panoramas de amenazas.
  SO-U12-Conceptos.pdf

Un agente de amenaza es un individuo o grupo de individuos que participa en la ejecución o el respaldo de un ataque. Para evaluar a un agente de amenaza se consideran sus motivaciones, capacidades e intenciones. Sus tipos son.

- Pasivo: Busca leer información sin autorización.
- Activo: Busca modificar información sin auntizarlo

Una amenaza es una causa potencial de un incidente no deseado que puede ocasionar daños a un sistema u organización. Los activos son los elementos que se busca proteger, como datos personales, información financiera, sistemas y procesos. Podemos dividirlo en dos conjuntos:

- Activos personales: Robo de identidad digital, acceso no autorizado a información financiera, robo de dinero y fraude.
- Activos de la organización: Alteración de páginas web, robo de nombres de dominio, infiltración de informes financieros, acceso no autorizado a información confidencial

Un panorama de amenazas es el conjunto de amenazas cibernéticas posibles e identificadas que pueden afectar a una persona, organización o sector durante un período determinado. El panorama varía dependiendo de:

- El sector y las características de la organización.
- El valor de la información que posee.
- El nivel de seguridad existente.
- Los factores geopolíticos y las técnicas de los atacantes.

- Relación entre vulnerabilidad, amenaza, riesgo e impactos.
  SO-U12-Conceptos.pdf

La vulnerabilidad es una debilidad de un sistema que puede ser aprovechada por una amenaza, es decir, una causa potencial de daño. Cuando una amenaza puede explotar esa vulnerabilidad, se genera un riesgo, que representa la posibilidad de que ocurra un incidente de seguridad. Si el incidente sucede, se produce un impacto, como la pérdida de información, el acceso no autorizado o la interrupción de un servicio. Por ello, el riesgo se evalúa considerando la probabilidad de ocurrencia y la magnitud del impacto.

- Clasificación de los controles de seguridad por tipo (técnico, legal, administrativo) y por función (preventivo, detección, correctivo).
  SO-U12-Conceptos.pdf

Clasificación	Categoría	Definición	Ejemplos
Por tipo	Técnico	Utiliza herramientas tecnológicas para proteger los	Cortafuegos, antivirus, cámaras

		sistemas y la información.	de vigilancia.
	Legal	Establece obligaciones mediante leyes, normas y contratos.	Leyes de protección de datos, contratos de confidencialidad.
	Administrativo	Establece políticas, procedimientos y responsabilidades para proteger la información.	Políticas de seguridad, separación de funciones y procedimientos de aprobación.
Por función	Preventivo	Busca evitar que ocurra un incidente de seguridad.	Contraseñas seguras, autenticación de dos factores.
	De detección	Permite identificar incidentes o amenazas de seguridad.	Alarmas, auditorías y monitoreo de accesos.
	Correctivo	Busca solucionar los problemas detectados y reducir sus consecuencias.	Restauración de copias de seguridad, corrección de vulnerabilidades.

3. Políticas y Mecanismos de Seguridad

- Vectores de ataque comunes y mecanismos:

Vector de ataque: es la ruta o medio por el cual un atacante obtiene acceso a un equipo o servidor de red para entregar un resultado malintencionado.

Mecanismo de ataque: es la forma en que se ejecuta el ataque. Puede ser un ataque singular, un mecanismo combinado o un ataque dirigido a un blanco específico. Pueden

propagarse mediante páginas web sospechosas, descargas sin verificación, correos no deseados, explotación remota, ataques de día cero y dispositivos extraíbles infectados.

- Ataques internos y sus estrategias de mitigación:
    - **Ataques Internos:** Son ataques que se originan dentro de la red privada de la organización y explotan vulnerabilidades desde dentro. A diferencia de los externos, que vienen de fuera (phishing, DDoS, suplantación de identidad).
    - **Mitigación:**
        - Capacitación regular contra el phishing.
        - Capacitar a los empleados para identificar y notificar comportamientos riesgosos entre sus colegas.
        - Fomentar la comunicación eficaz entre los departamentos de TI y RR. HH.
        - Controles técnicos para analizar e identificar comportamiento sospechoso de usuarios.
        - Soluciones de prevención de pérdida de datos (DLP) de red y punto extremo, para detectar acceso no autorizado a archivos.
        - Soluciones SIEM (gestión de eventos e información de seguridad) para identificar actividades internas maliciosas.

- Ataques externos principales según ENISA: Malware, Ransomware, Ingeniería Social, Amenazas contra los datos (fugas y violaciones), Amenazas contra la disponibilidad (DDoS) y Desinformación:
    - **Malware:** software malicioso diseñado para poner en peligro y dañar el sistema informático y la seguridad. Incluye virus, gusanos, troyanos, puertas traseras, spyware, botnets y ransomware. Puede propagarse por la red y permanecer sin detectar durante mucho tiempo. Datos del informe: aumento por cryptojacking y malware de IoT (botnets Mirai y Mozi), ataques a la cadena de suministro de código abierto (typo-squatting en NPM, Python, RubyGems), abandono de macros de Office a favor de contenedores (ISO, ZIP, RAR) y archivos LNK, y malware móvil dirigido (Pegasus, Predator).
    - **Ransomware:** malware que exige un rescate, últimamente en criptomoneda, para devolver el acceso a datos y sistema. Suele usar otros malware (frecuentemente troyanos) para el acceso inicial. Fue considerada la principal amenaza en la UE durante 2021. Cifras: al menos 15,45 % de usuarios de internet sufrió algún malware, 20 % de las violaciones cibernéticas en 2022 fueron ransomware, unos 236,1 millones de ataques en el primer semestre de 2022 y más de 130 familias (Gandcrab la más prevalente).
    - **Ingeniería social:** técnica que explota el comportamiento o los errores humanos para acceder a información o servicios, atrayendo a los usuarios a abrir archivos o correos, visitar sitios web o dar acceso no autorizado. Vectores: phishing, spear phishing, whaling, smishing, vishing, ataque al correo empresarial (BEC), fraude, suplantación de identidad y falsificación.
    - **Amenazas contra los datos:** buscan explotar las fuentes de datos para acceder a ellos, revelarlos o manipularlos. Se dividen en:

        - **Violación de seguridad:** ataque intencional para obtener acceso no autorizado.
        - **Fuga o filtración:** evento involuntario por fallos técnicos, vulnerabilidades o errores humanos.
    - También preocupa la manipulación y el envenenamiento de datos en modelos de ML/IA. En las estadísticas, el 24 % de las violaciones se atribuyó a fallos de TI y el 21 % a errores humanos.
    - **Amenazas contra la disponibilidad (DDoS):** el DDoS apunta a la disponibilidad de sistemas y datos. Ocurre cuando los usuarios no pueden acceder a datos o servicios porque el servicio, sus recursos y la infraestructura de red están sobrecargados. Esta categoría incluye también las amenazas de internet (destrucción física de infraestructura, supresión de información, CA controlada por gobiernos, secuestro de BGP).
    - **Desinformación e información errónea:** difusión de información falsa o engañosa para manipular a individuos u organizaciones. El desarrollo de IA y de servicios en la nube contribuye a fabricar información maliciosa.
- Medidas específicas de mitigación para cada tipo de ataque externo:

Malware:

1. Desarrollo y pruebas del plan de respuesta a incidentes
2. Análisis de vulnerabilidades y gestión de parches
3. Acceso remoto seguro y gestión de privilegios
4. Concienciación y capacitación en seguridad
5. Intercambio de información de malware con pares y CERT
6. Supervisión de registros y desarrollo de casos de uso
7. Implementación de EDR/XDR e inspección de tráfico
8. Detección de malware multicanal
9. Inventario y gestión de activos

Ransomware:

1. Estrategias de copia de seguridad seguras
2. Plan de respuesta a incidentes
3. Seguridad de la infraestructura orientada a internet
4. Controles de acceso
5. Concienciación y capacitación en seguridad
6. Colaboración con pares y CERT
7. Supervisión centralizada de registros
8. Gestión de activos
9. Seguridad de dispositivos finales
10. Filtrado de correo electrónico

Ingeniería social:

- Mantener y actualizar regularmente la huella digital de la organización.
- Designar una función de investigación de inteligencia de código abierto (OSINT).
- Registrar dominios que se asemejen al nombre de la organización.
- Capacitaciones de concienciación sobre nuevas tendencias de ingeniería social.

- Asegurar que los registros de la organización sean completos, confiables y coherentes.
- Ampliar la supervisión de dominios y certificados.
- Emplear inteligencia de amenazas para detectar actividades de ingeniería social.
- Suscribirse a alertas de transparencia de certificados y sitios de supervisión de violaciones de datos.

Amenazas contra los datos:

1. Establecer un equipo de respuesta y descubrir activos y evaluar riesgos
2. Planificar presupuestos y gastos de seguridad eficaces
3. Implementar una estrategia integral de ciberseguridad
4. Realizar auditorías de seguridad de datos
5. Saneamiento de datos y contramedidas contra el envenenamiento de datos y el aprendizaje automático adversarial
6. Soluciones de prevención de pérdida de datos (DLP)
7. Copias de seguridad y recuperación de datos

Disponibilidad (DDoS):

- Equipo de especialistas para responder a ataques DDoS.
- Validar acuerdos de terceros e información de contacto.
- Plan de contingencia para restaurar el servicio.
- Descubrimiento de activos, evaluación de riesgos y plan de mitigación para elementos críticos (servidores, servicios, aplicaciones).
- Apoyar la infraestructura de red con buenas prácticas (BCP): políticas de acceso a la red y filtrado de tráfico.
- Actualizar y aplicar parches a todos los sistemas.

Desinformación:

1. Leyes y regulaciones
2. Capacitación y concienciación
3. Información mediática de alta calidad
4. Alfabetización mediática
5. Desacreditar historias falsas
6. Utilización de IA
7. Prácticas resilientes para los procesos de recolección y distribución
8. Validación de fuentes y comprobación de inteligencia
9. Vigilancia de la red
10. Certificación y verificación de contenidos
11. Herramientas de detección y mitigación en redes sociales

4. Validación

- Principios de ingeniería de seguridad de sistemas y ciclo de vida de desarrollo (SDLC).

Integración de protecciones (capas, políticas, límites físicos/lógicos y modelado de amenazas) incorporando consideraciones de seguridad y privacidad a lo largo de todo el ciclo de vida del desarrollo de sistemas.

- Controles y comprobación de la seguridad de las aplicaciones web.

  Controles a nivel de código (autenticación, autorización, cifrado, registros) y herramientas de comprobación (SAST, DAST, IAST, SCA, MAST, RASP) según la etapa de desarrollo, además de restricciones de dominios/IPs.

- Criptografía y sus objetivos.

  Uso de algoritmos y claves para proteger la información y evitar análisis de tráfico, buscando cuatro objetivos principales: confidencialidad, integridad, autenticación y no repudio.

- Simétrica, asimétrica e híbridos

  La simétrica usa una clave y es rápida para grandes volúmenes; la asimétrica usa un par de claves (pública/privada) para asegurar autenticidad y distribución; los sistemas híbridos combinan la velocidad de la simétrica con la eficiencia en el intercambio de claves de la asimétrica.

- Gestión de claves:

  Procesos seguros para la generación automatizada con generadores de bits aleatorios (RBG), distribución, almacenamiento protegido, archivado, recuperación y destrucción de claves.

- Gestión de vulnerabilidades:

  Proceso compuesto por cuatro fases: Identificación (descubrimiento de activos y fallas), Evaluación (priorización con CVSS), Solución (parches y actualizaciones) y Notificación (registros e informes).

- Configuración y cambios en TI:

  Planificación, establecimiento de líneas base seguras y control de modificaciones (NIST SP 800-128), junto con un proceso formal de gestión de cambios para coordinar, implementar y auditar actualizaciones sin corromper datos.

- Controles contra el malware (prevención, detección y corrección).

  Medidas de prevención (cortafuegos, cifrado), detección (antivirus, IDS, supervisión de registros) y corrección (eliminación de código, parches según criticidad y copias de seguridad online/offline).

5. Protección y Control de Acceso

- Implementación de controles de acceso.

  Los controles de acceso establecen límites lógicos y físicos para restringir qué sujetos (usuarios, procesos o dispositivos) pueden acceder a determinados recursos u objetos dentro de un sistema operativo y red.

  Principio del menor privilegio: Otorgar únicamente los permisos estrictamente necesarios para ejecutar una tarea.

  Separación de funciones: Dividir responsabilidades críticas entre distintas entidades para prevenir fraudes o mal uso de privilegios.

  Reducción del anonimato: Garantizar la trazabilidad para identificar de forma única la autoría de cada acción.

  Alcance de los controles: Aplica tanto al acceso físico a las instalaciones y equipos como al acceso lógico a datos, redes, aplicaciones y servicios en la nube.

- Mecanismos de control: Identificación, Autenticación, Autorización y Rendición de cuentas (IAAA).

  El modelo **IAAA** es el marco estándar para la gestión de identidades y acceso en los sistemas.

  1. **Identificación:** El usuario declara quién es ante el sistema utilizando un identificador único (como su username o ID).
  2. **Autenticación:** El sistema verifica la identidad declarada mediante contraseñas, tokens o biometría (MFA).
  3. **Autorización:** Se otorgan los permisos específicos para operar sobre recursos según modelos como DAC, MAC, RBAC o ABAC.
  4. **Rendición de Cuentas:** Se registran y auditan las acciones en logs o SIEM para asegurar la trazabilidad y el no repudio.

6. Modelos Formales de Protección

Los modelos formales son estructuras teóricas y matemáticas que dictan cómo un sistema debe aplicar las políticas de seguridad para gestionar el flujo de información y controlar los accesos. Garantizan que el sistema opere en un estado seguro.

- **Modelo Bell-LaPadula:** Se enfoca estrictamente en la confidencialidad. Sus reglas principales son "no leer hacia arriba" y "no escribir hacia abajo" .
- **Modelo Biba:** Se centra en la integridad de los datos. Invierte las reglas de Bell-LaPadula: prohíbe "leer hacia abajo" y "escribir hacia arriba".
- **Modelo Clark-Wilson:** Protege la integridad en entornos comerciales. Requiere que los usuarios accedan a los datos solo a través de programas específicos o transacciones bien formadas, implementando la separación de funciones.
- **Modelo Brewer-Nash:** Diseñado para evitar conflictos de intereses. El sistema bloquea dinámicamente el acceso a los datos de una empresa si el usuario ya ha accedido a la información de un competidor directo.

7. Retroalimentación y Referencias

Esta fase asegura que el programa de ciberseguridad no sea estático, sino que evolucione frente a nuevas amenazas tecnológicas e incidentes operativos.

- **Retroalimentación:** Consiste en recopilar datos de auditorías, métricas de rendimiento y lecciones aprendidas tras la respuesta a incidentes. Utiliza ciclos como el de Deming para parchear vulnerabilidades descubiertas y actualizar las políticas de seguridad.
- **Referencias:** Las estrategias de seguridad deben basarse en estándares reconocidos internacionalmente y regulaciones legales. Las referencias más comunes incluyen la familia ISO/IEC 27000, el marco NIST CSF, los Controles CIS, y normativas de privacidad como el RGPD o leyes locales de protección de datos personales.